



Caso Bankitor — Arquitectura de Seguridad TO-BE

CURSO DE ESPECIALIZACIÓN EN CIBERSEGURIDAD Y
SEGURIDAD DE LA INFORMACIÓN

INTEGRANTES:

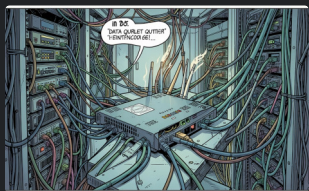
- CAJUSOL MIO , Christian
- CARRASCO GUEVARA, Diego
- MANAYAY REYES, Giomar
- SALDAÑA REYNOSO, Freddy

DOCENTE: Javier Benvenuto Servat

Horizonte: Corto, Mediano y Largo Plazo

Contexto del problema

Bankitor: entidad financiera peruana con >10 años de operación, regulada por la SBS. Cuenta con SOC tercerizado y Tecnologías de Seguridad Informática (TSI) instaladas, pero presenta brechas operativas críticas.



Incidente 1 — Caída de Internet

Cambio en router de borde provocó interrupción. El análisis forense no determinó los comandos ejecutados (falta de trazabilidad AAA/TACACS+).



Incidente 2 — BD de Créditos alterada

Modificación masiva: saldos cambiados a cero. Forense no identificó qué DBA o aplicación ejecutó la modificación (falta de auditoría SQL y controles de acceso).

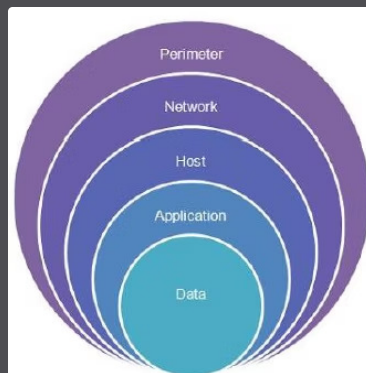
⚠ Riesgo latente: Banca por Internet expuesta sin WAF — vector de alto impacto para integridad y disponibilidad.

Defense in Depth — Modelo de Ciberseguridad

DiD **guía toda la arquitectura** en el corto, mediano y largo plazo, definiendo cómo se diseña y evoluciona la seguridad de punta a punta.

Asignación por capas

Cada control se ubica en una capa específica del modelo: Perimeter, Network, Host, Application y Data. Así, la protección se distribuye de forma coherente según el activo y el riesgo de cada nivel.



Rol del modelo

DiD no reemplaza la estrategia de seguridad; funciona como el **marco de referencia** para ordenar controles, priorizar inversiones y sostener la arquitectura en el tiempo.



3 defectos del modelo

- Asume una ruta lineal basada en la arquitectura de red.
- Puede generar capacidades superpuestas o discontinuas entre capas.
- Tiene una perspectiva limitada de amenazas: no incorpora Kill Chain, inteligencia ni respuesta.

📌 **Largo plazo:** la evolución del modelo incorpora **Zero Trust + SOAR + Threat Intelligence** para corregir estas limitaciones y fortalecer la capacidad de detección, respuesta y adaptación.

Evolución del Marco de Seguridad: DiD a Zero Trust

1

Corto Plazo

DiD — cerrar brechas críticas

Enfoque en las 5 capas principales del modelo.

2

Mediano Plazo

DiD — detectar y segmentar

Ampliación a las 5 capas con implementación de VLANs.

3

Largo Plazo

DiD + Zero Trust

"Nunca confíes, siempre verifica"
Integración de SOAR y Threat Intelligence.

❗ **Nota:** Zero Trust no reemplaza al DiD — se construye SOBRE él. Requiere que MFA, PAM, VLANs y SIEM ya estén maduros (corto/mediano plazo).

Clasificación de activos críticos — Business-Critical Subset

1 BD de Créditos (saldos)

Tipo: Datos/Información [D] — Valoración: 5 (Crítico)

2 Banca por Internet

Tipo: Servicios [S] — Valoración: 5 (Crítico)

3 Router de Borde DC1/DC2

Tipo: Red/Comunicaciones [COM] — Valoración: 5 (Crítico)

4 Datos de clientes

Tipo: Datos Personales [DP] — Valoración: 5 (Crítico)

5 Firewall / Balanceador

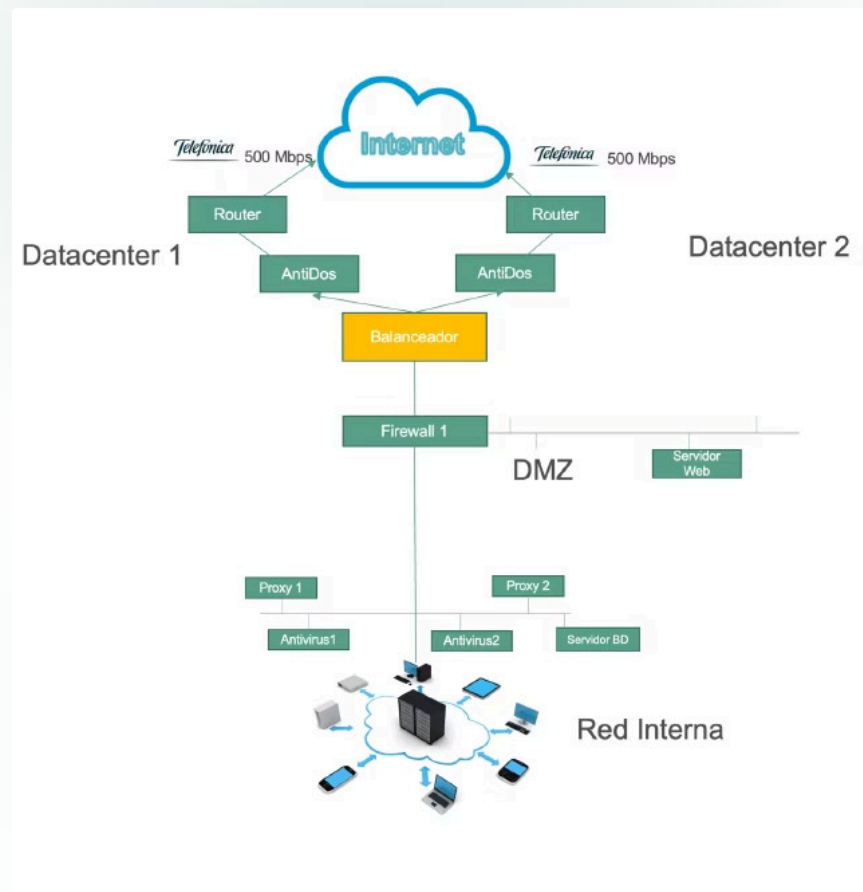
Tipo: Hardware [HW] — Valoración: 4 (Severo)

Frase clave: El alcance prioriza el Business-Critical Subset: la intersección entre Servicios, Activos de Información y Sistemas Físicos.

Diagrama AS-IS — Problemas principales

- ❌ Router sin trazabilidad de comandos (sin AAA / TACACS+)
- ❌ BD de Créditos sin auditoría SQL
- ❌ Balanceador sin Alta Disponibilidad — punto único de falla
- ❌ Firewall sin Alta Disponibilidad
- ❌ Red interna plana — sin dominios de seguridad
- ❌ Banca por Internet sin WAF
- ❌ Sin SIEM con casos de uso configurados para los activos críticos

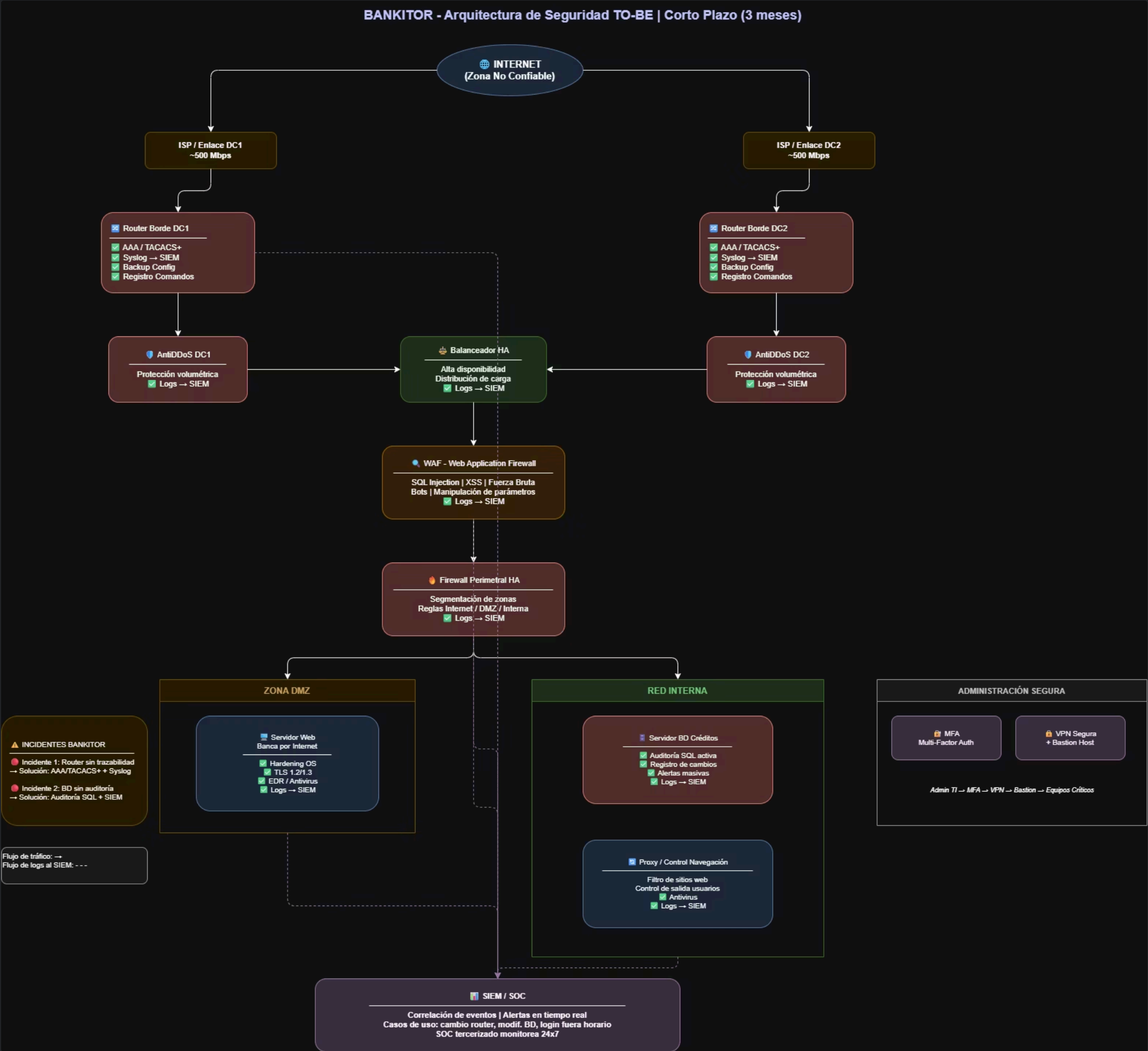
Estos elementos configuran un AS-IS con baja trazabilidad, poca segmentación y detección insuficiente.



Corto Plazo (0–3 meses) — Arquitectura TO-BE

Este diagrama representa la arquitectura de seguridad a implementar en el corto plazo (0-3 meses) para Bankitor, enfocándose en abordar las brechas críticas identificadas.

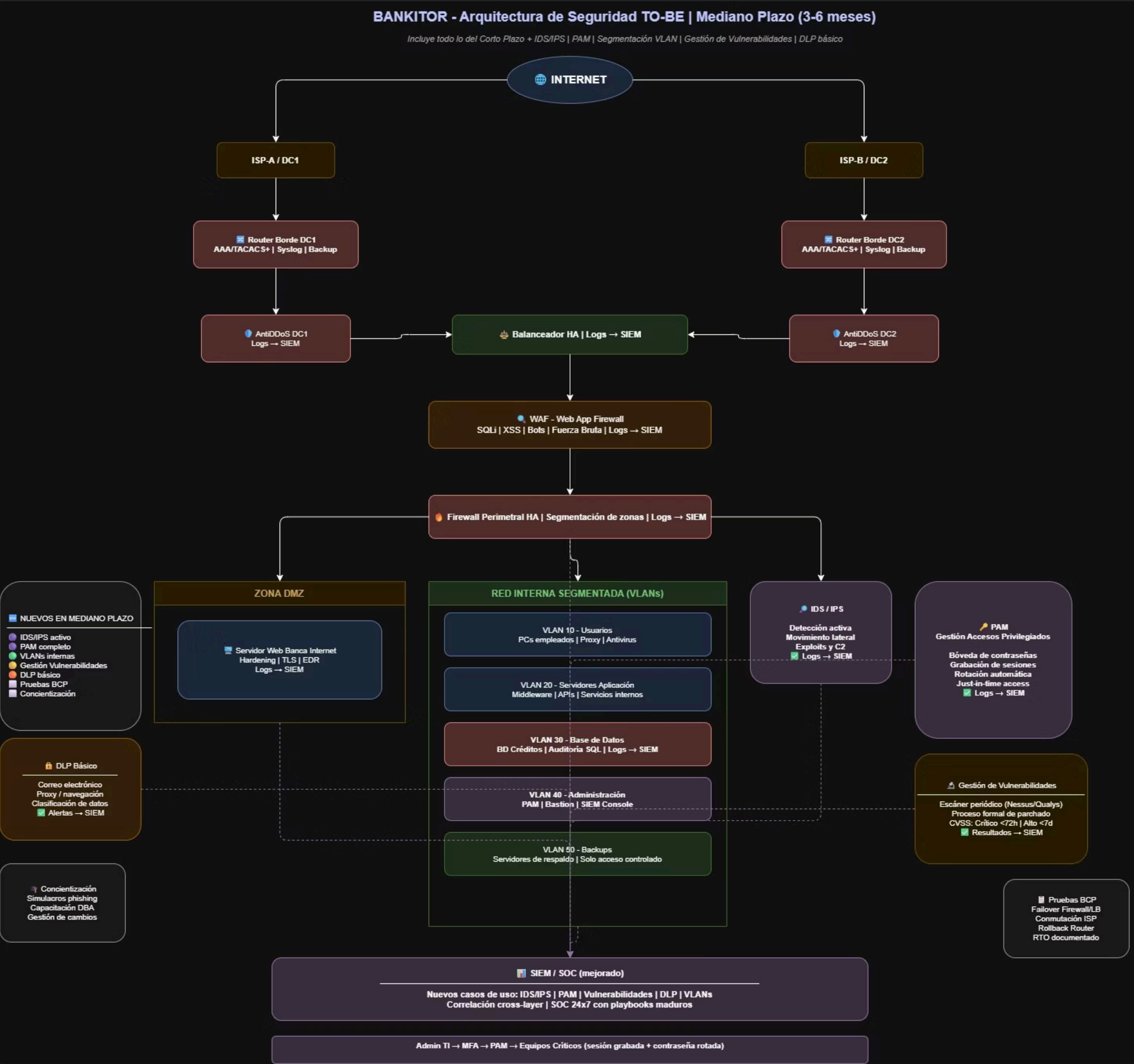
Todos los componentes envían logs al SIEM/SOC



Corto Plazo — ¿Qué implementamos y por qué?

Control	Qué es	Capa DiD	Resuelve
AAA / TACACS+ en routers	Registro de quién ejecutó cada comando en el router	Perímetro	Incidente 1
Auditoría SQL en BD Créditos	Trazabilidad de cada INSERT/UPDATE en la BD	Data	Incidente 2
WAF	Firewall de capa 7 — filtra ataques web (SQLi, XSS)	Aplicación	Riesgo latente
Syslog centralizado	Recolección unificada de logs de todos los equipos	Transversal	Análisis forense
Balanceador HA	Dos balanceadores activo-pasivo — sin punto único de falla	Red	Disponibilidad
Firewall HA	Dos firewalls activo-pasivo — sin punto único de falla	Perímetro	Disponibilidad
MFA + VPN + Bastion Host	Acceso administrativo con doble factor y punto de entrada único	Perímetro	Acceso admin
SIEM con casos de uso	Correlaciona logs y genera alertas automáticas al SOC	Transversal	Detección

Mediano Plazo (3-6 meses)



Mediano Plazo (3–6 meses)

Objetivo: Crear dominios de seguridad internos y detección activa en capa de red.

IDS/IPS

Capa Red — Detecta movimiento lateral entre dominios.

PAM (reemplaza Bastion)

Capa Aplicación/Data — Graba sesiones, rota credenciales, acceso just-in-time.

VLANs

Capa Red — Dominios internos: Usuarios, Aplicación, BD, Administración, Backups.

Gestión de Vulnerabilidades

Capa Host — Escaneo formal, priorización por CVSS y remediación.

DLP básico

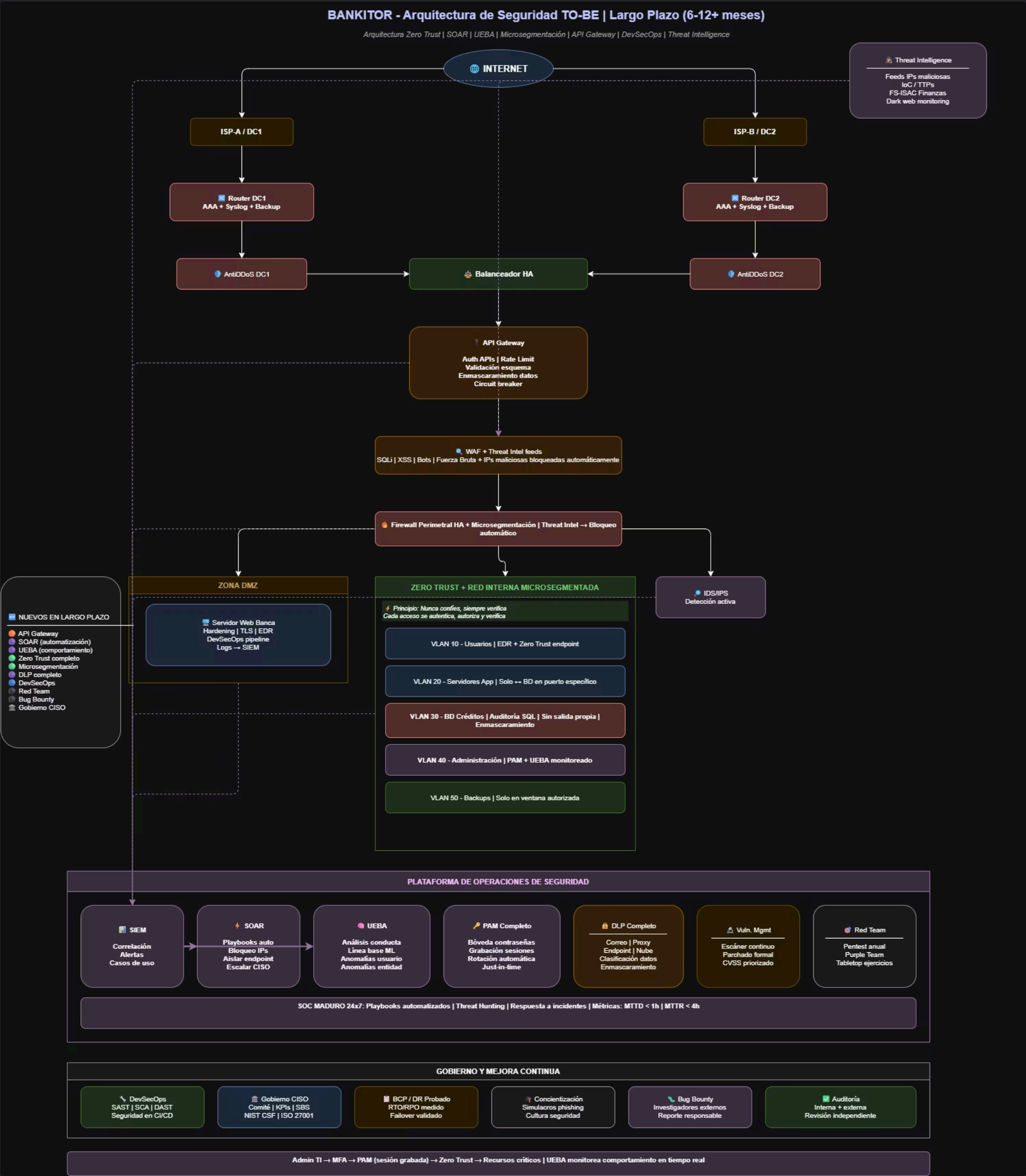
Capa Data — Prevención de exfiltración vía correo y proxy.

📌 Las VLANs crean múltiples perímetros internos — el DiD incluye defensa interna además del perímetro externo.

Mediano Plazo — ¿Qué incorporamos y por qué?

Control	Qué es	Capa DiD	Beneficio
IDS / IPS	Detecta y bloquea intrusiones dentro de la red	Red	Detecta movimiento lateral
PAM	Gestión de accesos privilegiados — graba sesiones, rota contraseñas	Aplicación / Data	Reemplaza Bastion básico
VLANs	Segmentación lógica de la red interna en dominios separados	Red	Contiene compromiso interno
Gestión de Vulnerabilidades	Escaneo formal de sistemas con priorización por CVSS	Host	Detecta brechas antes del ataque
DLP básico	Previene que datos sensibles salgan del banco sin autorización	Data	Controla exfiltración
Hardening de protocolos	Elimina Telnet, FTP, SSHv1, TLS antiguo — refuerza NTP, SNMP	Host / Red	Reduce superficie de ataque
Pruebas de continuidad	Failover real de firewall, balanceador e ISP documentado	Transversal	Valida el BCP

Largo Plazo (6-12+ meses)



Largo Plazo (6–12+ meses)

Objetivo: Inteligencia de amenazas y respuesta automatizada para corregir los defectos del DiD.

Defecto del DiD	Control aplicado
Arquitectura de red lineal	Microsegmentación por workload
Capacidades superpuestas	API Gateway complementa WAF
Sin inteligencia/respuesta	Threat Intelligence + SOAR + Red Team + UEBA

Zero Trust

"Nunca confíes, siempre verifica" – soportado por MFA + PAM + VLANs + SIEM.

SOAR

Automatiza respuestas: bloqueo IP, aislamiento endpoint, escalado al CISO.

UEBA

Detecta anomalías de comportamiento – habría señalado la modificación masiva sin regla específica.

Red Team & Threat Intel

Simulaciones del kill chain y feeds accionables para detección proactiva.

Largo Plazo — ¿Qué incorporamos y por qué?

Control	Qué es	Capa DiD	Defecto DiD que corrige
Zero Trust	"Nunca confíes, siempre verifica" — acceso mínimo y continuo	Transversal	Defecto 3: sin respuesta adaptativa
SOAR	Automatiza respuesta a incidentes con playbooks predefinidos	Transversal	Defecto 3: sin respuesta
UEBA	Detecta comportamiento anómalo de usuarios y entidades	Data / Host	Defecto 3: sin inteligencia
Threat Intelligence	Feeds externos de IPs maliciosas, dark web, TTPs actuales	Transversal	Defecto 3: sin intel de amenazas
Microsegmentación	Aísla cargas de trabajo individuales — más granular que VLANs	Red	Defecto 1: arquitectura lineal
API Gateway	Controla y autentica el tráfico entre APIs internas y externas	Aplicación	Defecto 2: capacidades superpuestas
DevSecOps	Seguridad integrada desde el desarrollo del software	Aplicación	Defecto 2: controles tardíos
Red Team anual	Simula el Cyber Kill Chain completo para validar defensas	Transversal	Defecto 3: sin validación real